

CORGI INSURANCE COMPANY, INC.

Cyber Protection Policy

For small and mid-sized businesses

Policy form CORG-CY-0200 (10/26) · Colorado edition · Specimen

Please read this entire policy carefully.

Coverages I, J, K, L and Q are claims-made and reported coverages. They apply only to **claims** first made against you during the **policy period** or an extended reporting period and reported to us as this policy requires. All other coverages apply to **incidents** you first **discover** during the **policy period**.

Claim expenses reduce the limits of insurance and count toward the **retention**.

Words in **bold** are defined in Section II.

To report an incident or claim, 24 hours a day: use any channel in Item 10 of the Declarations.

Important Notices and Disclaimers

Declarations

Section I. Insuring Agreements

Section II. Definitions

Section III. Coverage Sections

Section IV. Exclusions

Section V. Conditions

In witness whereof, Corgi Insurance Company, Inc. has caused this policy to be signed by its President and its Secretary. This policy is not valid unless completed by Declarations issued by us.

President

Secretary

Important Notices and Disclaimers

1. **Specimen.** This is a specimen policy form. It has not been filed with or approved by any insurance regulator, is not an offer of insurance and provides no coverage. Items in [brackets] are completed when a policy is issued.
2. **Claims-made liability coverage.** Coverages I, J, K, L and Q apply only to **claims** first made against you during the **policy period** (or an extended reporting period) and reported to us as the policy requires.
3. **Defense costs reduce your limits.** Amounts we pay for lawyers and other **claim expenses** reduce, and can use up, your limits, and count toward your **retention**.
4. **State edition.** This is the Colorado edition of the policy. A policy issued in another state includes that state's amendatory endorsement, which changes this policy where that state's law requires.
5. **Your privacy.** We collect information from your application, our security scans and claims to underwrite and service your policy. We share it only with our reinsurers, service providers and incident response panel, or as the law requires. We never sell it.
6. **Sanctions.** We cannot provide coverage or make any payment, including a ransom payment, that U.S. trade or economic sanctions prohibit.
7. **Terrorism (disclosure under the Terrorism Risk Insurance Act).** Coverage for acts of terrorism certified under the federal Terrorism Risk Insurance Act, as amended, is included in this policy on the same terms, conditions and exclusions as other covered losses. Losses from certified acts of terrorism may be partly reimbursed by the United States Government under a formula set by federal law. Under that formula, the United States Government generally reimburses 80% of covered terrorism losses above the deductible that the law sets for the insurance company providing the coverage. The Act contains a \$100 billion cap that limits U.S. Government reimbursement, and insurers' liability, for losses from certified acts of terrorism when those losses exceed \$100 billion in any one calendar year. If the combined insured losses of all insurers exceed \$100 billion, your coverage may be reduced. The portion of your annual premium attributable to this coverage is shown in Item 3 of the Declarations.
8. **Fraud warning (Colorado).** It is unlawful to knowingly provide false, incomplete, or misleading facts or information to an insurance company for the purpose of defrauding or attempting to defraud the company. Penalties may include imprisonment, fines, denial of insurance, and civil damages. Any insurance company or agent of an insurance company who knowingly provides false, incomplete, or misleading facts or information to a policyholder or claimant for the purpose of defrauding or attempting to defraud the policyholder or claimant with regard to a settlement or award payable from insurance proceeds shall be reported to the Colorado Division of Insurance within the Department of Regulatory Agencies.

IF YOU SUSPECT AN INCIDENT

1. **Call the hotline in Item 10 first.** A breach coach answers 24/7. The first 7 days of expert help cost you nothing, up to \$25,000.
2. **Don't pay a ransom, negotiate or admit fault** before talking to us. You never have to pay a ransom to keep your coverage.
3. **Preserve evidence.** Don't wipe or rebuild systems until our forensic team says so.
4. **Money sent to a fraudster? Call your bank at once,** then us. The first 24 hours matter most for getting it back.
5. **Make legally required notices on time.** You never need our permission to meet a legal deadline.

This summary does not change the policy. The policy wording controls.

Declarations

Corgi Insurance Company, Inc. · Cyber Protection Policy · Form CORG-CY-0201 (10/26)

This policy contains claims-made and reported coverage. Claim expenses reduce the limits of insurance and count toward the retention. Please read the entire policy carefully.

Policy number	[Policy number]
New or renewal	[New / Renewal of policy number]
Producer	[Producer name and address, or "Direct"]

ITEM 1. NAMED INSURED AND ADDRESS

[Named insured] · [Street address, city, state, ZIP code] · Websites and email domains: [domains]

ITEM 2. POLICY PERIOD

From [effective date] to [expiration date], both at 12:01 a.m. standard time at the address in Item 1.

ITEM 3. PREMIUM

Premium line	Amount
Premium, including optional coverages purchased in Item 6	\$(amount)
Portion attributable to certified acts of terrorism (TRIA)	\$0
Taxes, surcharges and fees	\$(amount)
Total	\$(amount)

ITEM 4. LIMITS OF INSURANCE

Limit	Amount
Policy aggregate limit	\$(1,000,000, 2,000,000 or 3,000,000). The most we will pay for all coverages combined during the policy period , including claim expenses
Incident response services (Coverage A)	\$25,000 each incident ; \$75,000 for the policy period . In addition to the policy aggregate limit, with no retention
Pre-incident assistance	\$2,500 for the policy period . In addition to the policy aggregate limit, with no retention
Proof-of-loss help	\$50,000 each incident . Part of the policy aggregate limit

ITEM 5. RETENTION

Retention	Amount
Each incident	[\$amount], after any retention credit in Item 7
Coverage H, reported within 72 hours	\$2,500
Claim-free reduction	25% for each consecutive claim-free year you renew with us, to a minimum of \$2,500 (Section V, part 6)

ITEM 6. COVERAGE SCHEDULE

Each limit is the most we will pay under that coverage for all **incidents** and **claims** in the **policy period** combined, and is part of the policy aggregate limit unless marked "in addition". "Policy aggregate" means the coverage can use the full policy aggregate limit. A limit marked "applies across coverages" is the most we will pay for that kind of loss under the coverages it names, combined (Section III, part 1.1).

Part 1: Core coverages (included in every policy)

Coverage	Limit for the policy period	Retention or waiting period
RESPONDING TO AN INCIDENT		
A Incident Response Services	\$25,000 each incident ; \$75,000 for the period (in addition)	None
B Breach Response Costs	Policy aggregate	Item 5
C Cyber Extortion and Ransomware	Policy aggregate	Item 5
LOST INCOME		
D Business Interruption	Security failure: policy aggregate †. System failure: \$250,000 for D and F combined, applies across coverages	8-hour waiting period
E Dependent Business Interruption	\$500,000	8-hour waiting period
DATA AND SYSTEMS		
F Data and System Restoration	Policy aggregate † (system failure: see D)	Item 5
G Security Improvement Costs	\$25,000	Included in the incident's retention
PAYMENT FRAUD		
H Payment Fraud and Invoice Fraud	\$250,000 for both parts combined; \$100,000 where Section III, part 6.2 applies †	Item 5; \$2,500 if reported within 72 hours
CLAIMS AND INVESTIGATIONS AGAINST YOU		
I Network Security and Privacy Liability	Policy aggregate	Item 5

	Coverage	Limit for the policy period	Retention or waiting period
J	Regulatory Defense and Penalties	Policy aggregate	Item 5
K	PCI Fines and Assessments	\$250,000	Item 5
L	Media Liability	Policy aggregate	Item 5
OTHER LOSSES			
M	Computer Replacement (Bricking)	\$100,000	Item 5
N	Reputational Harm	\$100,000	14-day waiting period, then up to 90 days of lost profit
O	Cryptojacking and Telecom Fraud	\$50,000	Item 5

Period of restoration for Coverages D, E and P: up to 180 days, plus catch-up costs for 30 days after it ends.

† **Your share beyond the retention.** Each of these applies only if the gap caused the **incident** or made the loss larger (Section III, part 1.9):

- **Backups not verified:** you pay 20% of ransomware restoration and downtime loss under Coverages D and F (Section III, part 1.6).
- **Known-exploited vulnerability left unpatched** more than 45 days after our written notice, and then used in an attack: you pay 20% of that **incident's** loss (Section III, part 1.7). Never more than 20% in total with the item above.
- **No payment verification procedure, or untrained staff:** Coverage H is limited to \$100,000 (Section III, part 6.2).

Part 2: Optional coverages (only if marked purchased)

	Optional coverage	Limit if purchased	Retention or waiting period	Purchased
P	Dependent System Failure Business Interruption	\$250,000	24-hour waiting period	☐
Q	Website Tracking Liability	\$250,000	Item 5	☐
R	Increased Fraud Limit	Coverage H limit raised to ☐ \$500,000 or ☐ \$1,000,000	As Coverage H	☐
S	Key Customer Interruption	\$100,000. Key customers: [names]	Item 5	☐
T	Impersonation Response	\$25,000	\$2,500	☐
	System Failure Full Limit	System failure limit for D and F raised to the policy aggregate limit	As D and F	☐

ITEM 7. SECURITY CREDITS

Credits are based on controls verified at issue. A credit continues only while the control stays in place; tell us within 30 days if you stop using it (Section III, part 1.5). Retention credits do not add together: the single largest one earned applies. The premium credit applies in addition.

Control	Credit	Earned
24/7 managed detection and response: endpoint alerts watched around the clock by a provider authorized to isolate devices	Retention reduced 50%; waiting period for Coverages D and E reduced to 4 hours	☐
Multi-factor authentication on email, remote access and administrator accounts, plus endpoint detection and response on all laptops and servers	Retention reduced 25%	☐
Hardened remote access: multi-factor authentication on every remote-access path, and no end-of-life VPN or remote-access tools	Premium reduced 10%	☐

ITEM 8. CLAIMS-MADE DATES

Date	Entry
Retroactive date	[Full prior acts, or date]
Continuity date	[Date: the first day of the first policy we issued to you, if renewed without a break]

ITEM 9. EXTENDED REPORTING PERIOD

Option	Terms
Automatic	60 days after the policy ends, if it is cancelled or not renewed (Section V, part 5.4)
Optional	12 months for 75% of the annual premium, or 24 months for 125% (Section V, part 5.5)

ITEM 10. REPORTING AN INCIDENT OR CLAIM (24/7)

Channel	Contact
Hotline	[24/7 incident hotline number]
Email	[Incident reporting email address]
Online	[Online reporting address]

Any of these channels, including a call to the hotline, is notice under this policy (Section V, part 1.1). Report as soon as possible. **Never delay a notice that the law requires you to make.**

ITEM 11. CHOICE OF LAW

Colorado. Colorado law does not allow punitive or exemplary damages to be insured, so this policy does not pay them.

ITEM 12. FORMS AND ENDORSEMENTS

Form	Title
CORG-CY-0201 (10/26)	Declarations
CORG-CY-0200 (10/26)	Cyber Protection Policy
CORG-CY-0202 (10/26)	Application
CORG-CY-0205-CO (10/26)	Colorado Amendatory Endorsement
CORG-IL-0001 (10/26)	Terrorism Risk Insurance Act Disclosure

These Declarations, together with the **application**, the policy form and any endorsements, complete this policy.

Authorized representative	Date
	[Date issued]

Section I. Insuring Agreements

In exchange for your premium, and relying on your **application**, we agree to provide the coverages below. They are subject to the limits, retentions, exclusions, conditions and other terms of this policy. Core coverages A–O apply to every policy. Optional coverages P–T apply only if Item 6 of the Declarations shows them as purchased.

Each coverage is set out the same way: when it applies, what we pay, the limit and your share, and any special conditions. Amounts are those shown in the Declarations; if an amount in this Section differs from the Declarations, the Declarations control.

WHEN COVERAGE APPLIES

Every coverage requires all of the following:

1. The **incident, media wrongful act** or **wrongful collection** first happened on or after the **retroactive date** and before the end of the **policy period**. For Coverage A, an actual or suspected **incident**, and for Coverage B, an actual or reasonably suspected **incident**, meets this requirement, even if an investigation later shows that none happened.
2. For coverages for your own losses (A–H, M–P, S and T), you first **discover** the **incident** during the **policy period**. For Coverages A and B, it is enough that you received an **early warning**, or reported a suspected **incident**, during the **policy period**.
3. For liability coverages (I–L and Q), the **claim** is first made against you during the **policy period** or any extended reporting period.
4. You report the **incident** or **claim** to us through any channel in Item 10, as Section V (Conditions) requires.

TERMS THAT APPLY TO EVERY COVERAGE

- **Artificial intelligence.** An **incident** or **claim** is not excluded merely because artificial intelligence, machine learning or synthetic media (including deepfakes) was used to cause, carry out or detect it.
- **We pay vendors directly.** Wherever possible, we pay covered vendors (forensics, lawyers, negotiators) directly, so you do not have to pay first and wait to be reimbursed.

RESPONDING TO AN INCIDENT (A–C)

A. Incident Response Services

When it applies. You report an actual or suspected **incident** through any channel in Item 10. An **early warning** is always a reasonably suspected **incident** for Coverages A and B.

What we pay. We provide **incident response services** for the first 7 days after your report.

Limit and your share. \$25,000 each **incident** and \$75,000 for the **policy period** (Item 4), in addition to the policy aggregate limit. No **retention**.

Special conditions. By itself, an **early warning** does not mean you have **discovered** an **incident** for any other coverage. How the response works: Section III, part 2.

B. Breach Response Costs

When it applies. An actual or reasonably suspected **security failure** or **privacy event**, including one involving paper records.

What we pay. Breach response costs, including the cost of finding out that no **security failure** or **privacy event** happened.

Limit and your share. Up to the policy aggregate limit (Item 4), after the **retention** (Item 5).

Special conditions. Costs must be incurred within 12 months after you **discover** the event or, for one that is only suspected, after you report it. Legally required notices never need our consent; voluntary notices do. Section III, part 2.

C. Cyber Extortion and Ransomware

When it applies. **Cyber extortion**, including **ransomware** that has already encrypted or locked your systems.

What we pay. Extortion expenses: negotiators, investigation, sanctions screening and legal advice on whether a payment is lawful and, only with our prior written consent and where lawful, a ransom or other extortion payment.

Limit and your share. Up to the policy aggregate limit (Item 4), after the **retention** (Item 5).

Special conditions. You never have to pay a ransom to keep any other coverage. If a payment cannot lawfully be made, or you decide not to pay, we still pay negotiation, investigation and sanctions-screening costs. Consent and reporting steps: Section III, part 3.

LOST INCOME (D–E)

D. Business Interruption

When it applies. A **security failure** or **system failure** interrupts your **computer systems** for longer than the **waiting period**. A partial outage that stops a significant part of your business, such as payroll processing, counts.

What we pay. The **business income loss** you incur during the **period of restoration** and your **extra expense**, including catch-up costs incurred up to 30 days after the **period of restoration** ends.

Limit and your share. For a **security failure**, up to the policy aggregate limit. For a **system failure**, \$250,000 for Coverages D and F combined (Item 6). No dollar **retention**: the **waiting period** in Item 6 applies instead (8 hours, or 4 hours with the managed detection credit in Item 7).

Special conditions. The **period of restoration** lasts up to 180 days. If your backups were not verified, ransomware coinsurance can apply (Section III, part 1.6). How we measure the loss: Section III, part 4.

E. Dependent Business Interruption

When it applies. A **security failure** affecting the **dependent systems** you rely on interrupts them for longer than the **waiting period**.

What we pay. The **business income loss** you incur during the **period of restoration** and your **extra expense**, including catch-up costs incurred up to 30 days after the **period of restoration** ends.

Limit and your share. \$500,000 (Item 6). No dollar **retention**: the **waiting period** in Item 6 applies instead (8 hours, or 4 hours with the managed detection credit).

Special conditions. Providers do not need to be named, but only technology and outsourced-processing providers are **dependent providers** (Section II). An outage caused by a provider's own non-malicious failure falls under Coverage P, if purchased. Section III, part 4.

DATA AND SYSTEMS (F–G)

F. Data and System Restoration

When it applies. A **security failure** or **system failure** damages, corrupts or deletes your **digital assets**, or leaves **malicious code** in your **computer systems**.

What we pay. **Restoration costs** to restore, recreate or recollect your **digital assets**, and to remove **malicious code** from your **computer systems**.

Limit and your share. For a **security failure**, up to the policy aggregate limit. For a **system failure**, the \$250,000 limit shared with Coverage D (Item 6). The **retention** (Item 5) applies.

Special conditions. If your backups were not verified, ransomware coinsurance can apply (Section III, part 1.6). Upgrades are paid only under Coverage G. Section III, part 5.

G. Security Improvement Costs

When it applies. After a **security failure** covered under Coverage B, C, D, F or H, our incident response team recommends in writing an upgrade to prevent a similar **incident**.

What we pay. **Security improvement costs** for that upgrade, including the first year of any subscription.

Limit and your share. \$25,000 (Item 6), within the **incident's retention**.

Special conditions. The upgrade must be made within 90 days after you **discover** the **security failure**. Section III, part 5.

PAYMENT FRAUD (H)

H. Payment Fraud and Invoice Fraud

When it applies. Either (1) **payment fraud** or **computer fraud** causes a **funds transfer loss**; or (2) a **security failure** lets someone send your customers fraudulent invoices or payment instructions, and you cannot collect payment you are owed.

What we pay. **Funds transfer loss**, including amounts you must repay clients from **client accounts** and reasonable recovery costs, and **invoice manipulation loss**.

Limit and your share. \$250,000 for both parts combined, or the Coverage R limit if purchased (Item 6). \$100,000 if you had no payment verification procedure or had not trained your staff, and that mattered (Section III, part 6.2). The **retention** (Item 5), or \$2,500 if you report the loss to us within 72 hours of **discovering** it.

Special conditions. Theft by your own owners, partners, employees or individual contractors is not **payment fraud** or **computer fraud**. Tell your bank at once and keep your rights against it. Section III, part 6.

CLAIMS AND INVESTIGATIONS AGAINST YOU (I–L)

I. Network Security and Privacy Liability

When it applies. A **claim** is first made against you, as described above, for a **security failure** or **privacy event**, including a **claim** by your own **employee** about their personal information.

What we pay. **Damages** and **claim expenses** you are legally obligated to pay.

Limit and your share. Up to the policy aggregate limit (Item 4), after the **retention** (Item 5). **Claim expenses** reduce the limit.

Special conditions. Errors in your professional services, such as accounting or tax advice, are not covered, but a breach that happens while you provide those services is (exclusion 20). We defend without waiting for your professional liability insurer (Section V, part 9.2). Defense and settlement: Section III, part 7.

J. Regulatory Defense and Penalties

When it applies. A **regulatory proceeding** arising from a **security failure** or **privacy event**.

What we pay. **Claim expenses**, and **regulatory penalties** you are legally obligated to pay where insurable, as that definition explains.

Limit and your share. Up to the policy aggregate limit (Item 4), after the **retention** (Item 5).

Special conditions. Costs of complying with orders or improving your security are not covered. Section III, part 7.

K. PCI Fines and Assessments

When it applies. A demand under your **merchant services agreement** because of a **security failure** or **privacy event** involving payment card data.

What we pay. **PCI fines and assessments** and **claim expenses** you are legally obligated to pay.

Limit and your share. \$250,000 (Item 6), after the **retention** (Item 5).

Special conditions. Chargebacks and ordinary processing fees are not covered.

L. Media Liability

When it applies. A **claim** for a **media wrongful act** in your **media content**.

What we pay. **Damages** and **claim expenses** you are legally obligated to pay, including for content created with artificial intelligence tools.

Limit and your share. Up to the policy aggregate limit (Item 4), after the **retention** (Item 5).

Special conditions. Patents and trade secrets are not covered (exclusion 11). Section III, part 7.

OTHER LOSSES (M–O)

M. Computer Replacement (Bricking)

When it applies. A **security failure** corrupts the firmware or software of computer hardware you own or lease, so that it no longer works as intended.

What we pay. **Computer replacement costs**, where replacement costs no more than repair.

Limit and your share. \$100,000 (Item 6), after the **retention** (Item 5).

Special conditions. Section III, part 8.

N. Reputational Harm

When it applies. An **adverse publication** about a **security failure** or **privacy event**.

What we pay. **Reputational harm loss** you incur during the **reputational harm period**.

Limit and your share. \$100,000 (Item 6). No dollar **retention**: the first 14 days after the **adverse publication** are not covered, and we then pay for up to 90 days (Item 6).

Special conditions. We do not pay loss already paid under Coverage D, E or P. The cost of repairing your reputation is paid under Coverage B. Section III, part 8.

O. Cryptojacking and Telecom Fraud

When it applies. A **security failure** allows unauthorized use of your computing resources, cloud or artificial intelligence services, utilities or telephone systems.

What we pay. **Service fraud loss.**

Limit and your share. \$50,000 (Item 6), after the **retention** (Item 5).

Special conditions. You must first ask your provider to waive or reverse the charges; we pay what it will not. Section III, part 8.

OPTIONAL COVERAGES (P–T, ONLY IF PURCHASED)

P. Dependent System Failure Business Interruption

When it applies. A **system failure** affecting the **dependent systems** you rely on interrupts them for longer than the **waiting period** shown for Coverage P in Item 6.

What we pay. The **business income loss** you incur during the **period of restoration** and your **extra expense**, including catch-up costs incurred up to 30 days after the **period of restoration** ends.

Limit and your share. \$250,000 (Item 6), separate from the Coverage D and F **system failure** limit. No dollar **retention**: a 24-hour **waiting period** applies instead.

Special conditions. Same measurement rules as Coverage E (Section III, part 4).

Q. Website Tracking Liability

When it applies. A **claim** alleging **wrongful collection** of personal information through **tracking technology** on your websites or apps.

What we pay. **Damages** and **claim expenses** you are legally obligated to pay.

Limit and your share. \$250,000 (Item 6), after the **retention** (Item 5).

Special conditions. Biometric information is not covered.

R. Increased Fraud Limit

The limit for Coverage H becomes the amount shown for Coverage R in Item 6 (\$500,000 or \$1,000,000). The lower limit in Item 6 still applies as Section III, part 6 says.

S. Key Customer Interruption

When it applies. A **key customer event** forces a **key customer** to cancel or reduce its orders from you.

What we pay. The net profit you lose, for the time the **key customer's** systems are down and for up to 90 days after they are restored.

Limit and your share. \$100,000 (Item 6), after the **retention** (Item 5).

Special conditions. Only customers named for Coverage S in Item 6 are **key customers**.

T. Impersonation Response

When it applies. You first **discover** an **impersonation event** during the **policy period**. No **security failure** or **privacy event** is needed.

What we pay. **Impersonation response costs.**

Limit and your share. \$25,000, with a \$2,500 **retention** (Item 6).

Special conditions. Costs must be incurred with our consent within 90 days after you **discover** the **impersonation event**.

SPECIMEN

Section II. Definitions

Words in **bold** have these meanings wherever they appear in this policy, including the Declarations.

Adverse publication means a report or communication to the public, through any news or online media, of previously non-public information about a **security failure** or **privacy event** affecting you.

AI agent means software you use that can take actions in your **computer systems** without a person approving each step. It exceeds its authority when it takes an action that its configured permissions did not permit, that your written instructions or policies prohibited, or that someone other than you caused it to take (for example, through instructions hidden in an email or document it processed).

Application means everything you, or anyone on your behalf, gave us in writing to obtain this policy, including the application form and its attachments. Our own security scans are not part of your **application**.

Breach response costs means the following reasonable costs you incur within 12 months after you **discover** a **security failure** or **privacy event** or, for one that is only suspected, within 12 months after you report it to us. Section V, part 2.2 explains when you need our consent.

1. Forensic experts to find the cause and scope of the **incident** and contain it.
2. Lawyers (a breach coach) to advise on your legal obligations, including notices to individuals and regulators.
3. Notifying affected individuals and regulators, including printing, postage, email and call center services.
4. Credit monitoring, identity monitoring and identity restoration for affected individuals for 24 months, or longer if the law requires.
5. Helping affected individuals respond to tax-related identity theft, such as filing an identity theft affidavit with the Internal Revenue Service or obtaining an identity protection PIN.
6. Public relations and crisis management consultants.
7. Voluntary notifications not required by law, if we agree in advance.

Business income loss means:

1. the net profit before taxes you would have earned, or the net loss you would have avoided, but for the interruption; and
2. normal operating expenses, including payroll, that must continue during the interruption.

Forensic accounting fees to prove this loss are covered as described in Section III, part 1.8. It does not include profit you would have earned only because a widespread event harmed your competitors.

Claim means:

1. a written demand for money, services or other relief;
2. a lawsuit, arbitration or mediation;
3. a **regulatory proceeding**;
4. a written demand for **PCI fines and assessments**; or
5. a written request to pause (toll) a statute of limitations for a potential claim.

All **claims** arising from the same or **related** facts are one **claim**, made on the date the first one was made.

Claim expenses means reasonable attorneys' fees and other costs to investigate, defend, settle or appeal a **claim**, incurred by us, with our consent, or as Section V, part 2.2 allows, including appeal bond premiums. It does not include your own staff's salaries or overhead. **Claim expenses** reduce your limits.

Client accounts means:

1. accounts you hold for clients, such as trust or escrow accounts; and
2. a client's own bank or payment account that you are authorized in writing to operate or to start payments from, for example to run the client's payroll or pay its bills.

Cloud accounts means the accounts, tenants, user identities, settings and data that you control in an online service, such as your email, file-storage, online banking, payroll, accounting and tax-software accounts and your client portal. It covers only what you control, not the provider's own servers, code or network.

Computer fraud means someone's unauthorized entry into, or use of, your **computer systems** (including your **cloud accounts**) to:

1. transfer money or securities from your accounts or **client accounts** without your permission; or
2. alter a payment batch, payroll file, or payee or bank record held in your **computer systems**, which you then approve or release without knowing it was altered.

It does not include a transfer or alteration made by, or in collusion with, your current owner, partner, member, officer, employee or individual independent contractor.

Computer replacement costs means the reasonable cost to replace computer hardware you own or lease with equivalent hardware, when a **security failure** has corrupted its firmware or software so that it no longer works as intended.

Computer systems means computers, servers, mobile devices, software, networks, storage, backup devices and connected devices (including Internet of Things devices) that are:

1. owned or leased by you, or operated by you, including your **cloud accounts**; or
2. personally owned by an **employee** or **executive** and used with your permission to access your systems or data.

It does not include **dependent systems**. If an attack on **dependent systems** gives someone unauthorized access to your **cloud accounts**, or damages, encrypts or exposes data in them, it is a **security failure** affecting your **computer systems** under every coverage. An interruption caused only because a **dependent provider's** service is unavailable to you, other than one caused by a **security failure** in your own **computer systems**, falls under Coverage E (or, for a **system failure**, Coverage P if purchased), not Coverage D.

Confidential business information means non-public business information of a third party in your care under a duty of confidentiality, such as a client's financial records.

Continuity date means the date shown in Item 8 of the Declarations.

Cyber extortion means a threat, made to obtain money, cryptocurrency, property or services from you, to:

1. release, sell or publish data in your care;
2. damage, encrypt, corrupt or disable your **computer systems** or **digital assets**, or continue doing so;
3. launch a denial-of-service attack against your **computer systems**; or
4. transfer funds from your accounts without permission.

It includes **ransomware** that has already encrypted or locked your systems.

Damages means judgments, awards and settlements you are legally obligated to pay, including pre- and post-judgment interest. Punitive or exemplary damages, and the multiplied part of any multiplied damages, are included only where the law shown in Item 11 of the Declarations allows them to be insured. **Damages** does not include:

1. fines, penalties or taxes, except **regulatory penalties** and **PCI fines and assessments** covered under Coverages J and K;
2. restitution, return of fees, or disgorgement of profits;
3. the cost of complying with an injunction or other non-monetary relief; or
4. amounts you owe only because you agreed to them in a contract, except: (a) amounts you would have owed anyway; (b) amounts you owe under a contract duty to keep **personal information** or **confidential business information** secure, or to pay for notifying people after a **privacy event**; and (c) **PCI fines and assessments** under Coverage K. We do not pay liquidated damages or service credits beyond what you would have owed without the contract.

Dependent provider means a business, other than an **insured**, that provides you, under a written or electronic agreement (including standard online terms you accepted), either: (1) information technology services, such as cloud hosting, software as a service, data storage, or managed IT or security services; or (2) outsourced business processes that it runs on its own computer systems, such as payroll, tax filing, billing or payment processing. It does not include other suppliers or customers, or a provider of electricity, water, gas or other utilities, telecommunications, or **public internet infrastructure**.

Dependent systems means the computer systems a **dependent provider** operates, or has a hosting or cloud provider operate for it, to provide services to you, other than your **cloud accounts**.

Digital assets means your electronic data and software. It does not include computer hardware.

Discover means the first time an **executive**, or the security contact named in your **application**, becomes aware of facts that would lead a reasonable person to believe an **incident** has happened or is happening, even if its cause, scope or cost is not yet known.

Early warning means a notice to you, from a law enforcement or other government agency, your bank, your outside IT provider, a **dependent provider**, a security company monitoring your systems, or us, that your **computer systems** may have been compromised or that your credentials or data are being offered or used by criminals.

Employee means any past or present employee, including part-time, seasonal, temporary and leased workers, interns and volunteers, while working for you.

Executive means your owner, managing partner or managing member; any partner or member holding 10% or more of the **named insured**; your chief executive officer, chief financial officer and general counsel; and the **employee** you have designated as responsible for information technology or security. It does not include an outside IT provider.

Extortion expenses means the following. Item 1 always requires our prior written consent. Items 2 and 3 need it only if you use a vendor outside our panel, and even then Section V, part 2.2 applies:

1. money, cryptocurrency or property paid to end **cyber extortion**, where lawful, and the cost of acquiring and transferring it;
2. fees of negotiators and other consultants to respond to the **cyber extortion**; and
3. the cost of screening payment recipients against sanctions lists, and of legal advice on whether a payment is lawful.

Extra expense means reasonable additional costs you incur to avoid or reduce **business income loss**, or to catch up on work the interruption delayed, such as renting equipment, paying overtime or temporary staff, hiring outside IT staff or moving work to other systems. It includes catch-up costs incurred up to 30 days after the **period of restoration** ends. Costs to avoid **business income loss** are covered up to the loss they avoid.

Financial institution means a bank, credit union, payroll or payment processor, broker-dealer or similar institution that holds or moves money or securities for you or your clients.

Funds transfer loss means money or securities taken from your accounts or **client accounts** resulting from **payment fraud** or **computer fraud**, and reasonable costs to try to recover them. For a client's own account, it includes only amounts you are legally obligated to repay the client, or repay with our consent, which we will not unreasonably withhold. It does not include personal funds of **employees** or **executives**, or chargebacks on payment cards used fraudulently. Wages or other amounts you must pay again because **payment fraud** or **computer fraud** diverted them are your loss, not an **employee's** personal funds.

Impersonation event (Coverage T only) means the publication or use, without your permission, of synthetic media (including deepfake audio or video), a lookalike website or internet domain, or a fake social media or messaging account, that falsely presents itself as you, or as an **executive** or **employee** speaking for you.

Impersonation response costs (Coverage T only) means reasonable costs, incurred with our consent within 90 days after you **discover** an **impersonation event**, for an expert to analyze whether content is fake; lawyers to ask platforms, registrars and hosts to remove the content, website, domain or account; public relations help; and warning your customers.

Incident means a **security failure**, **system failure**, **privacy event**, **cyber extortion**, **payment fraud**, **computer fraud**, **adverse publication** or, if purchased, an **impersonation event** (Coverage T) or **key customer event** (Coverage S). **Incidents** arising from the same or **related** facts are one **incident**, occurring when the first one occurred.

Incident response services means the following, provided through our 24/7 hotline for the first 7 days after you report an actual or suspected **incident**, up to the amounts in Item 4: consultation with a breach coach lawyer, initial forensic triage and containment guidance, and guidance on legal notice deadlines.

Insured, you and your mean:

1. the **named insured** and any company it owns more than 50% of;
2. **executives** and **employees**, while acting for you;
3. individual independent contractors, while working for you under your supervision; and
4. for Coverage I only, any person or organization you agreed in a written contract to add as an additional insured, but only for liability caused by your acts.

In Coverages A–H, M–P, S and T, "you" and "your" mean the **named insured** and its subsidiaries, except where a definition says otherwise.

Invoice manipulation loss means your direct net cost, excluding profit, of goods or services you delivered or will deliver, when a customer's payment to you is diverted because it paid a fraudulent invoice or followed fraudulent payment instructions sent as a result of a **security failure**. It does not matter whether you delivered before or after the diverted payment.

Key customer (Coverage S only) means a customer named for Coverage S in Item 6 that provided more than 10% of your revenue in the 12 months before the **policy period**.

Key customer event (Coverage S only) means an attack of the kind described in the definition of **security failure** on a **key customer's** own computer systems.

Malicious code means software designed to damage, disrupt, steal from or gain unauthorized access to computer systems, including viruses, worms, spyware and **ransomware**.

Media content means text, images, audio, video and other material, whether created by people or with artificial intelligence tools, that you publish on your websites, social media accounts, advertising or marketing. It does not include your products or software.

Media wrongful act means any of the following in your **media content**: defamation or disparagement; invasion of privacy or publicity rights; infringement of copyright, trademark, trade name or domain name (but not patents or trade secrets); or plagiarism.

Merchant services agreement means your agreement with a bank, payment processor or card brand that lets you accept payment cards.

Named insured means the organization shown in Item 1 of the Declarations.

Payment fraud means a deliberate deception by someone who is not your current owner, partner, member, officer, employee or individual independent contractor (whether or not acting for you at the time), and who is not acting in collusion with one, by any means of communication (including email, text, messaging app, letter, phone or video call, and synthetic or deepfake audio or video), in which that person pretends to be, or to act for, you, an **executive**, **employee**, client, vendor, **financial institution** or other person you deal with, or falsely claims that genuine payment or bank details have changed, and that:

1. leads you, or a **financial institution** that holds your accounts or **client accounts**, to transfer money or securities, or to change payment or bank details that are then used for a transfer; and
2. causes a loss to you, or a loss you must make good to a client.

In this definition, "you" means the **named insured** acting through anyone authorized to make, approve or change its payments, including an **executive**, **employee**, individual independent contractor, or an **AI agent** acting within its authority.

PCI fines and assessments means fines, fraud recoveries, card reissuance costs and case management fees you owe under a **merchant services agreement** because of a **security failure** or **privacy event** involving payment card data. It does not include chargebacks or ordinary processing fees.

Period of restoration means the time that begins when an interruption of **computer systems** or **dependent systems** begins and ends when your operations are restored, or could have been restored with reasonable speed, to their level before the interruption, but no longer than 180 days. Reasonable speed never assumes that a ransom was paid.

Personal information means information about an identifiable individual that any law, in the United States or elsewhere, requires to be protected, in electronic or paper form, including Social Security, taxpayer identification, driver's license and passport numbers; financial account and payment card numbers; tax return information; health information; biometric data; and usernames and passwords.

Policy period means the period shown in Item 2 of the Declarations, ending earlier if the policy is cancelled.

Privacy event means:

1. unauthorized access to, or loss, theft or disclosure of, **personal information** or **confidential business information** in your care, in electronic or paper form, including while a **dependent provider** holds it for you;
2. your failure to give notice of a breach as a breach notification law requires; or

3. your failure to follow your own published privacy policy on protecting, sharing or giving people access to **personal information**.

It does not include **wrongful collection**.

Public internet infrastructure means the public domain name system (its root and top-level-domain servers), internet exchange points and internet backbone networks. It does not include **dependent systems**, including the name servers a **dependent provider** or its hosting provider runs for its own services.

Ransomware means **malicious code** that encrypts or locks data or systems in order to demand payment.

Regulatory penalties means civil fines, penalties and consumer redress amounts imposed in a **regulatory proceeding**, where insurable under the law shown in Item 11 of the Declarations, or of the place where the **regulatory proceeding** is brought, whichever allows it. It does not include the cost of complying with orders or improving your security practices.

Regulatory proceeding means a request for information, civil investigative demand, investigation or civil proceeding, arising from a **security failure** or **privacy event**, by:

1. a U.S. federal, state or local government agency (such as the Federal Trade Commission, a state attorney general or the U.S. Department of Health and Human Services); or
2. a government agency or data protection authority outside the United States.

Related facts are facts that share a common cause or the same attacker's continuing access, or that form a causally connected series.

Reputational harm loss means the net profit before taxes you lose during the **reputational harm period** as a direct result of an **adverse publication**. It does not include the cost of repairing your reputation, which is covered as **breach response costs**.

Reputational harm period means the period shown in Item 6 of the Declarations (up to 90 days), beginning when the reputational harm waiting period shown there ends. The waiting period begins on the date of the first **adverse publication**.

Restoration costs means reasonable costs to restore, recreate or recollect **digital assets** to their condition before the **security failure** or **system failure**, from backups or original sources, and to remove **malicious code**, including the cost to determine that restoration is not possible. It does not include the value of the data itself, the cost of creating new data or software, or upgrades other than **security improvement costs**.

Retention means the dollar amount shown in Items 5 and 6 of the Declarations that you pay for each **incident** before we pay. Section III, part 1.3 explains how it works. For business interruption, the **waiting period** applies instead; for reputational harm, the reputational harm waiting period in Item 6 applies instead.

Retroactive date means the date shown in Item 8 of the Declarations. "Full prior acts" means there is no retroactive date.

Security failure means any of the following affecting your **computer systems**, including when caused by an **employee** or **executive** acting outside their authority or against your interests:

1. unauthorized access to or use of **computer systems**, including with stolen credentials or credentials obtained by deception;
2. infection by **malicious code**;
3. a denial-of-service attack;
4. loss or theft of a device containing your data; or

5. someone other than you causing an **AI agent** to exceed its authority in your **computer systems**, including through instructions hidden in content it processes.

For Coverage E, it means the same events affecting **dependent systems**.

Security improvement costs means reasonable costs, incurred within 90 days after you **discover** a covered **security failure**, of security measures our incident response team recommends in writing to prevent a similar **incident**, such as multi-factor authentication, endpoint detection and response, or improved backups. It includes the first year of any subscription.

Service fraud loss means charges from your cloud, hosting, artificial intelligence, utility or telephone providers for unauthorized use that the provider will not waive or reverse.

System failure means an unplanned and unintentional outage of **computer systems** not caused by a **security failure**. It includes one caused by human error, a programming error, a faulty software update or patch (including one released by a vendor), or an **AI agent** malfunctioning or exceeding its authority without anyone else causing it to. It does not include planned downtime, or a failure of electricity, water, gas or other utilities, telecommunications, satellites or **public internet infrastructure** that you do not operate (for Coverage P, that neither the **dependent provider** nor its hosting or cloud provider operates). For Coverage P, it means the same events affecting **dependent systems**.

Tracking technology means pixels, cookies, software development kits, session replay tools, chatbots and similar tools that collect information about visitors to your websites or apps.

Waiting period means the number of hours shown in Item 6 of the Declarations (or Item 7, if a security credit applies) that an interruption must last before business interruption coverage begins. We do not pay loss incurred during the **waiting period**.

We, us and **our** mean the insurer shown on the Declarations.

Wrongful collection means collecting, recording, sharing or using personal information through **tracking technology** without legally required notice or consent, including under wiretapping, eavesdropping or video privacy laws such as the California Invasion of Privacy Act.

Section III. Coverage Sections

Part 1 applies to every coverage. Parts 2 to 8 set out how each coverage works once an **incident** or **claim** happens.

1. LIMITS AND RETENTIONS

1. **How the limits work.** The policy aggregate limit in Item 4 of the Declarations is the most we will pay for all coverages combined, including **claim expenses**. Each limit in Item 6 is the most we will pay under that coverage for all **incidents** and **claims** in the **policy period** combined, and is part of the aggregate limit, not in addition to it, unless Item 6 says "in addition". A limit marked "applies across coverages" is the most we will pay for that kind of loss under the coverages it names, combined, whichever of them the loss falls under. The system failure limit is such a limit: it caps **business income loss**, **extra expense** and **restoration costs** caused by a **system failure** under Coverages D and F combined. It does not reduce Coverage P, which has its own limit.
2. **Services outside the aggregate.** Coverage A and pre-incident assistance (Section V, part 2.3) are provided in addition to the aggregate limit, up to the amounts in Item 4, and no **retention** applies to them.
3. **One retention per incident.**
 1. One dollar **retention** applies to each **incident** and every **claim** arising from it, even if they trigger several coverages or fall in different policy periods. If different retentions could apply, the largest one applies.
 2. Business interruption has the **waiting period** instead of a dollar **retention**, and reputational harm has the reputational harm waiting period in Item 6.
 3. **Claim expenses** count toward the **retention**, and so do payments by other insurance or by others on your behalf.
 4. If you earn the reduced Coverage H **retention**, it is the only dollar **retention** for the Coverage H loss, and what you pay toward it counts toward any other **retention** for the same **incident**.
4. **Settling within your retention.** You may settle a **claim** yourself if the total cost, including **claim expenses**, stays within your **retention** and you obtain a full release from every claimant.
5. **Security credits.** The credits in Item 7 apply to every **incident** you **discover** while the verified control is in place for substantially all the users, devices and accounts it covers. Exceptions you disclosed in your **application** never count against you. If you stop using a verified control, tell us within 30 days. The credit stops for **incidents** you **discover** after you stopped, and resumes when you restore the control. A control disabled by the attacker during the **incident** itself does not lose the credit.
6. **Ransomware coinsurance.** If your backups were not verified when the **incident** happened, you pay 20% of the **restoration costs**, **business income loss** and **extra expense** under Coverages D and F that result from **ransomware** encrypting or locking your **computer systems**, after the **retention**. We pay the other 80%, up to the applicable limit. This coinsurance applies across Coverages D and F. It does not apply to **extortion expenses**, **breach response costs** or liability coverages. Backups are verified if you successfully tested restoring from them within the 12 months before the **incident** and kept a copy that is offline or immutable. If you restore the affected **digital assets** from your own backups anyway, this coinsurance does not apply to that **incident**.
7. **Known-exploited vulnerabilities.** This rule applies only to a vulnerability on the U.S. Cybersecurity and Infrastructure Security Agency's Known Exploited Vulnerabilities catalog that we described in writing to your main contact and your security contact, naming the affected system. If, more than 45 days after our notice, you have neither patched it nor applied the vendor's or the agency's published mitigation, and an attacker then uses

it in an **incident**, you pay 20% of the loss from that **incident**, after the **retention**. This applies even if our pre-issue scan showed the vulnerability. If both this rule and part 6 apply to the same loss, you pay 20% in total, not 40%. This is the only way patching can reduce what we pay for a loss. Section V, part 6.1 explains how fixing critical issues affects the claim-free reduction.

8. **Proof-of-loss help.** We pay up to \$50,000 per **incident** for an independent forensic accountant to help you prove any loss under the coverages for your own losses. This reduces the aggregate limit but not the limit of the coverage it supports.
9. **How your security can affect what we pay.** Only three terms can reduce what we pay because of your security practices: the ransomware coinsurance (part 1.6), the known-exploited-vulnerability coinsurance (part 1.7) and the lower Coverage H limit (part 6.2 of this Section). Each applies only if we show that the missing control or procedure caused the **incident** or made the loss larger. If we show that, the term applies as its part describes. No exclusion or condition reduces what we pay because of your security practices. Separately, your **retention, waiting period** and claim-free reduction depend on the security credits and conditions in part 1.5 and Section V, part 6. They are part of your price. What you told us in your **application** is dealt with in Section V, part 3.

2. INCIDENT RESPONSE AND BREACH RESPONSE (COVERAGES A AND B)

1. Call our 24/7 hotline, or use any channel in Item 10, as soon as you suspect an **incident**. A breach coach lawyer will guide the response.
2. Where possible, forensic experts are hired through the breach coach, so their work stays protected by legal privilege.
3. Vendors on our panel are pre-approved. You may use another vendor with our consent, which we will not unreasonably withhold, at rates similar to our panel's.
4. **Breach response costs** must be incurred within 12 months after you **discover** the **incident** or, for one that is only suspected, within 12 months after you report it to us.
5. **You decide on legally required notices.** You may notify individuals, regulators and law enforcement as the law requires without waiting for our consent, and we will pay the reasonable costs under Coverage B.

3. CYBER EXTORTION AND RANSOMWARE (COVERAGE C)

Paying is never required. Whether to pay is your decision, made with our consent under the steps below. You never have to pay a ransom to keep any other coverage. We will not reduce what we pay under any coverage because you chose not to pay, even if paying might have shortened the outage.

Before any extortion payment:

1. **Contact us.** We will arrange an experienced negotiator.
2. **Assess the threat together.** We and you will consider whether the threat is credible and whether you can restore from backups instead of paying.
3. **Report the attack.** Before we consent to a payment, the attack must be reported to the FBI (through its Internet Crime Complaint Center) or to the U.S. Cybersecurity and Infrastructure Security Agency, unless law enforcement advises otherwise. Our breach coach will make the report for you if you ask.
4. **Check that payment is lawful.** We will pay for sanctions screening and a lawyer's advice on whether a payment is lawful. We will not pay, and you must not pay, anyone that sanctions laws prohibit paying.
5. **Get our written consent.** We will not unreasonably withhold consent to a lawful payment. We may make the payment directly.

Laws about paying. If a law requires you to notify a government agency before or after an extortion payment, to wait for permission, or to explain a payment afterwards, you may do so without our consent, and we will pay the reasonable legal cost under Coverage C. A delay the law requires is not a breach of this policy. If a law forbids the payment, we will not pay it, but Coverage C still pays negotiation, investigation and advice costs. Payments in cryptocurrency are valued on the date paid.

4. BUSINESS INTERRUPTION (COVERAGES D, E AND P)

1. **How we calculate your loss.** We look at your net profit and operating expenses over the 12 months before the interruption, adjusted for trends, seasonality (such as a retailer's holiday season or an accounting firm's tax season) and the business you would likely have had.
2. **Partial outages count.** An interruption includes a partial outage, or a slowdown, that stops you from carrying on a significant part of your normal business, such as processing payroll or filing tax returns, even while other systems still work. We measure the loss of the part of your business affected.
3. **Shutting down to limit damage.** If you shut down or disconnect **computer systems**, or your connection to **dependent systems**, to contain an actual or reasonably suspected **security failure** (in your systems or at a **dependent provider**), the resulting interruption is treated as caused by that **security failure**, under Coverage D or E as the case may be. This applies if you act on the advice of our incident response team, a government agency or a **dependent provider**, or in your own reasonable judgment. If the suspected **security failure** did not happen, we cover up to 72 hours of the interruption.
4. **Waiting periods.** The **waiting period** starts when the interruption begins. Item 6 shows it for each coverage, and Item 7 shows any reduction you earned. If an interruption from the same **incident** stops and starts again, the interrupted hours add up toward the **waiting period**. It applies once per **incident**, however many systems or providers are affected.
5. **Dependent providers do not need to be named.** Coverages E and P apply to any **dependent provider** as defined in Section II. Other suppliers and customers are not **dependent providers**; Coverage S can cover key customers.
6. **Proof of loss.** Send us a signed proof of loss within 120 days after the **period of restoration** ends. We will extend this deadline on request if you need more time. Forensic accounting fees to prepare it are covered as described in part 1.8.
7. **Getting back to business.** You must take reasonable steps to resume operations. Reasonable steps do not include paying a ransom or other extortion payment. We may review the records that relate to your loss for up to 12 months after receiving your proof of loss.

5. DATA RESTORATION AND SECURITY IMPROVEMENTS (COVERAGES F AND G)

1. We restore **digital assets** from backups or original sources to their condition before the **security failure** or **system failure**. If they cannot be restored, we pay the reasonable cost of establishing that.
2. If the same software or equipment is no longer available, we pay for the closest current equivalent.
3. Coverage G is the only way this policy pays for upgrades. Our incident response team must recommend the upgrade in writing, and you must make it within 90 days after you **discover** the **security failure**. We pay the first year of any subscription, not later renewals.

6. FRAUD (COVERAGES H AND R)

1. **Verification procedure.** The full Coverage H limit in Item 6 applies if, when the loss happened, you had a written procedure requiring whoever receives a request to confirm it before acting. The confirmation must use a phone number from your own records (never one supplied in the request) or another channel set up in advance. The procedure must cover: (a) any request to add or change the bank or payment details of a vendor, client, **employee** or client's employee; and (b) any request to transfer more than \$5,000 received by email, text, messaging app, phone or video call.
2. **When the lower limit applies.** The \$100,000 limit in Item 6 applies only if you did not have that procedure, or had not trained the people who acted on the request, and part 1.9 of this Section is met. It never applies to **computer fraud**, to **invoice manipulation loss**, or to **payment fraud** in which the party deceived was a **financial institution**. If you had the procedure and trained your people, a failure to follow it, by one person or several on the same request, does not reduce your limit. A request sent from, or through, a compromised mailbox or account is still **payment fraud** for this part.
3. **Act fast.** Tell your bank and report the fraud to the FBI's Internet Crime Complaint Center as soon as possible, ideally within 24 hours. Our funds-recovery team will help. Reporting to us within 72 hours of **discovery** earns the reduced **retention** in Item 6.
4. **Keep your rights against the bank.** Under the law on funds transfers, a bank must sometimes refund an unauthorized or fraudulent transfer. Tell your bank in writing about any such transfer as soon as you can, and within the time your account agreement and the law allow. We will not wait for the bank's decision before paying covered loss. After we pay, we may pursue the bank in your name under Section V, part 10.
5. **Recoveries.** Money recovered after we pay goes first to reimburse your **retention** and any uninsured loss, then to us.
6. **Invoice fraud.** We pay **invoice manipulation loss** once you show that the customer paid the fraudulent account and you have made reasonable efforts to collect.

7. LIABILITY CLAIMS (COVERAGES I, J, K, L AND Q)

1. **Defense.** We have the right and duty to defend any covered **claim**, even if the allegations are groundless. You may choose defense counsel from our panel, or other counsel we agree to at similar rates.
2. **Settlement.** We will not settle a **claim** without your consent. You may refuse a settlement we recommend that the claimant would accept. If you do, we pay the settlement amount and the **claim expenses** incurred up to your refusal, and 70% of further **damages** and **claim expenses**. You pay the rest.
3. **Defense costs reduce your limits.** Our duty to defend ends when the applicable limit is used up.
4. **Mixed claims.** If a **claim** includes both covered and uncovered allegations, we pay 100% of **claim expenses** until the covered allegations are resolved, and we allocate **damages** fairly between covered and uncovered matters.
5. **Penalties and punitive damages.** We pay **regulatory penalties** only where insurable, as that definition explains, and punitive damages only as the definition of **damages** allows.

8. BRICKING, REPUTATIONAL HARM AND CRYPTOJACKING (COVERAGES M, N AND O)

1. **Computer replacement (M).** We pay to replace hardware with equivalent hardware when replacement costs no more than repair.
2. **Reputational harm (N).** After the reputational harm waiting period in Item 6, we calculate **reputational harm loss** the same way as **business income loss**, excluding any loss already paid under Coverages D, E or P.

3. **Cryptojacking and telecom fraud (O).** This includes extra cloud, artificial intelligence service, utility and telephone charges. You must first ask your provider to waive or reverse the unauthorized charges; we pay what the provider will not.

SPECIMEN

Section IV. Exclusions

This policy does not cover loss, **claims** or costs arising from the matters listed below. Each exclusion applies only as written. Where an exclusion says it does not apply to something, that exclusion does not remove coverage for it; whether it is covered still depends on the insuring agreements, definitions and other terms of this policy.

1. **Bodily injury and property damage.** Physical injury, sickness or death, or physical damage to tangible property. This does not apply to emotional distress claims under Coverages I and L, or to Coverage M.
2. **Known problems.** Any **incident, claim** or circumstance that an **executive** knew about before the **continuity date** and that a reasonable person in that role would have expected to lead to a **claim** or loss, or that you reported under an earlier policy that covers it. A circumstance does not include: (a) a vulnerability, missing patch or other security weakness that, as far as any **executive** knew, had not been exploited; (b) anything disclosed in your **application**, unless the Declarations or an endorsement exclude it; or (c) an **early warning** that an investigation completed before the **continuity date** found was not an **incident**.
3. **Before the retroactive date.** Any **incident, media wrongful act** or **wrongful collection** that first happened before the **retroactive date**.
4. **Intentional wrongdoing by executives.** Any deliberately dishonest, fraudulent or malicious act, or knowing violation of law, by an **executive**, or by anyone acting with an **executive's** knowledge and consent. This exclusion applies only after a final, non-appealable ruling in the matter or in a separate proceeding, or the person's written admission, establishes the act. Until then we defend **claims** and pay covered loss under every coverage. It does not apply to any **insured** who did not take part in or know about the act. For the **named insured**, it applies only if its owner, managing partner or managing member, chief financial officer or general counsel took part in the act, or knew about it and let it continue.
5. **Contract promises.** Liability you took on under a contract. This does not apply to amounts covered under item 4 of the definition of **damages**, or to liability you would have had without the contract.
6. **Claims between insureds.** A **claim** by one **insured** against another, or by a company that owns more than 20% of you or that you own more than 20% of. This does not apply to a **claim** by any individual **insured** about their own **personal information**, or to a **claim** by an additional insured.
7. **Employment practices.** Wrongful termination, discrimination, harassment or other employment-related claims, except an **employee's claim** arising from a **security failure** or **privacy event**.
8. **Securities, antitrust, benefits and racketeering laws.** Violations of securities, antitrust, employee-benefits (ERISA) or racketeering (RICO) laws, or unfair or deceptive trade practices. The last part does not apply to a **regulatory proceeding** arising from a **security failure** or **privacy event**, or to a **claim** under Coverage I or Q arising from a **security failure, privacy event** or **wrongful collection**.
9. **Unsolicited communications.** Violations of laws restricting calls, texts, faxes or emails, such as the Telephone Consumer Protection Act or the CAN-SPAM Act. This does not apply if a **security failure** caused the communications.
10. **Wrongful collection and biometric laws.** **Wrongful collection**, except under optional Coverage Q; or violations of the Illinois Biometric Information Privacy Act or similar laws governing how biometric data is collected, kept or used. This does not apply to **breach response costs**, or to liability arising from a **security failure** that exposes biometric data.
11. **Patents and trade secrets.** Infringement of patents or misappropriation of trade secrets. Other intellectual property claims are covered only under Coverage L.

12. **Infrastructure failures.** Failure or interruption of electricity, water, gas or other utilities, telecommunications, satellites or **public internet infrastructure** that you do not operate, whatever the cause. This does not apply to loss from a **security failure** affecting your **computer systems**, or, under Coverages E and P, to a **security failure** or **system failure** within **dependent systems**.
13. **Natural disasters and physical events.** Fire, flood, earthquake, windstorm, explosion or other natural or physical catastrophe. This does not apply to theft or loss of a device, or to physical access used to carry out a **security failure**.
14. **Government orders.** Seizure, confiscation or destruction of your systems or data by order of a government authority, or an order to shut down your systems. This does not apply to a **regulatory proceeding**, or to a law enforcement request to preserve or hand over evidence about a covered **incident**.
15. **War and state-backed cyber operations.**
1. **What is excluded:** (a) war, including a cyber operation carried out as part of a war; or (b) a state-backed cyber operation that has a major detrimental impact on the functioning of another state, because of its effect on that state's security or defense or on the availability, integrity or delivery of its essential services. War means the use of physical force by one state against another, or civil war, rebellion, revolution, insurrection or military takeover, whether or not war is declared. A state-backed cyber operation is one carried out by, at the direction of, or under the control of a state. Essential services include financial, health, utility, emergency, food, energy and transportation services. In this exclusion, "state" means a sovereign country, and "government" means its national government. It never means a U.S. state.
 2. **Bystanders stay covered.** Part (b) does not apply to your **computer systems**, or a **dependent provider's** systems, located outside the country that suffered the major detrimental impact. Your **cloud accounts** are treated as located at your address in Item 1.
 3. **Cyber terrorism and state-linked crime stay covered.** Attacks by non-state groups for political, religious or ideological goals, and ransomware, espionage or fraud by groups linked to a state, are not excluded unless (a) or (b) applies.
 4. **How attribution works.** We will rely on attribution by the national government of the country where your affected **computer systems** (for Coverage E, the affected **dependent systems**) are located. Until that government attributes the operation, we may rely on other objectively reasonable evidence, which we will share with you. **We bear the burden of proving this exclusion applies.**
 5. **We keep helping while attribution is pending.** Coverage A, **breach response costs** and defense of **claims** continue until we establish that this exclusion applies. We will not seek repayment of amounts already paid.
16. **Nuclear and pollution.** Nuclear reaction, radiation or radioactive contamination, or the release of pollutants.
17. **Prohibited payments.** Any payment that trade or economic sanctions laws prohibit us from making, including reimbursing you for a payment you made to a person those laws prohibit paying.
18. **Investment losses.** Changes in the value of securities, cryptocurrency or other assets, or trading losses. This does not apply to **funds transfer loss** or **extortion expenses**.
19. **Profits you weren't entitled to.** Any profit or advantage you were not legally entitled to, once a final, non-appealable ruling or the person's written admission establishes it. Until then we will defend the **claim**.
20. **Professional services.** Errors, omissions or advice in your professional services, such as accounting, tax preparation, audit or payroll calculations. This does not apply to a **claim** or loss arising from an **incident** or a **media wrongful act**, even if it happened while you were providing professional services.

Section V. Conditions

These conditions apply to every coverage.

1. REPORTING INCIDENTS AND CLAIMS

1. **How to give notice.** Tell us through any channel in Item 10 of the Declarations as soon as practicable after you **discover** an **incident** or a **claim** is made against you. A call to the hotline is notice under this policy; you do not need to send anything else to give notice. We will confirm each report to you in writing, by email, within one business day. Your notice is effective when you give it, even if our confirmation is late. For a **claim**, also send us a copy of the demand, lawsuit or other document you received as soon as practicable.
2. **Deadline for claims.** You must report a **claim** no later than 90 days after the **policy period** ends. For a **claim** first made during an optional extended reporting period, the deadline is 60 days after that period ends. These deadlines are firm, except as part 1.4 says.
3. **Late notice of incidents.** If you report an **incident** late, we will reduce what we pay only to the extent the delay actually harmed our ability to respond to it.
4. **Reports lock in coverage.** If, during the **policy period** or within 90 days after it ends, you report an **incident** you **discovered** during the **policy period**, or facts you learned of during the **policy period** that could reasonably lead to a **claim**, every later **claim** arising from it, or from the same or **related** facts, is treated as first made and reported on the date you reported, or on the last day of the **policy period** if you reported after it ended. It is covered only under this policy, whenever it is actually made. You do not need to say who might sue. Send us each such **claim** as soon as practicable after it is made; the deadline in part 1.2 does not apply to it.
5. **Legal deadlines come first.** Nothing in this policy requires you to delay a notice, filing or report to affected individuals, regulators or law enforcement that you reasonably believe the law requires.

2. WORKING TOGETHER

1. You will cooperate with us, give us the information we reasonably need, and give our forensic team access to affected systems.
2. **Consent.** Do not admit liability or settle a **claim** without our consent. You never need our consent to use vendors on our panel; to make notices, filings or reports the law requires; to take reasonable steps to contain an attack in the first 72 hours; or to settle within your **retention**. If you incur other costs without our consent, we will reimburse reasonable and necessary costs that are otherwise covered, unless the lack of consent actually harmed us. Complying with a breach notification law is not an admission of liability.
3. **Pre-incident assistance.** If you have a security question before anything is suspected and before any **early warning** (such as whether an email is phishing, or whether a vendor's security terms are adequate), we will provide up to \$2,500 per **policy period** of legal or forensic advice. This is in addition to the aggregate limit, has no **retention**, and is not treated as a **claim**.

3. YOUR APPLICATION

1. We issued this policy relying on your **application**.
2. **Honest mistakes do not void your policy.** We will not rescind this policy, add exclusions, reduce limits or deny coverage because of an unintentional error or omission in your **application**. Only answers to questions we asked in the **application** can count as an error or omission. If an answer was inaccurate, we may change only

the premium, the **retention** and the security credits in Item 7 to what they would have been had we known the correct answer. If we would not have issued this policy at all, it still continues until the end of the **policy period**, and we may choose not to renew it (part 5.3).

3. **Rescission only for deliberate misstatements.** We may rescind this policy only if an **executive** knowingly and intentionally made a material misstatement in the **application**. A rescission applies only to the **named insured** and to **insureds** who made or knew about the misstatement. One **insured's** knowledge is not imputed to any other **insured**, except that an **executive's** knowledge is imputed to the **named insured**.
4. **What our scan saw, we accept.** We will not deny or reduce coverage, or claim misrepresentation, because of any condition our pre-issue security scan showed, except as Section III, part 1.7 allows after our written notice.

4. CHANGES DURING THE POLICY PERIOD

1. **New companies.** A company you acquire is automatically covered if its revenue is less than 25% of yours. Larger acquisitions are covered for 90 days; tell us within that time, and we may adjust the premium to keep covering them.
2. **If you are acquired.** If another organization acquires or merges with the **named insured**, this policy continues until the end of the **policy period**, but only for **incidents**, **media wrongful acts** and **wrongful collection** before the change. You may buy an extended reporting period.
3. **Security changes.** Tell us within 30 days if you stop using a verified control shown in Item 7 (Section III, part 1.5).

5. CANCELLATION, NON-RENEWAL AND EXTENDED REPORTING

1. **You may cancel at any time.** We will refund the unused premium pro rata.
2. **We may cancel only** for non-payment of premium, on 10 days' written notice stating the reason, or because an **executive** knowingly made a material false statement in your **application**, on 45 days' written notice. An honest mistake is never a reason to cancel (part 3.2). We will send any notice by first-class mail to the address in Item 1, and give longer notice if state law requires.
3. **Non-renewal and renewal changes.** We will give at least 60 days' written notice if we will not renew. If we offer to renew with a higher premium or reduced coverage, we will send you by first-class mail, at least 45 days before this policy ends, the renewal terms, the premium due, each change and the reasons for it.
4. **Automatic extended reporting.** If this policy is cancelled or not renewed, then for 60 days after it ends, **claims** first made against you during those 60 days, arising from **incidents**, **media wrongful acts** or **wrongful collection** that first happened before this policy ended, are treated as made on the last day of the **policy period**. This does not apply to a **claim** covered by other cyber insurance you buy to replace this policy.
5. **Optional extended reporting.** If either of us cancels or does not renew this policy, for any reason other than non-payment or a knowingly false statement in your **application**, you may buy an extended reporting period of 12 months for 75% of the annual premium, or 24 months for 125%. Tell us within 60 days after the policy ends. Any extended reporting period is part of the aggregate limit, not in addition to it.

6. RENEWAL BENEFITS

1. **Claim-free retention reduction.** For each consecutive claim-free year you renew with us, your dollar **retention** drops by 25% of the **retention** then in effect, to a minimum of \$2,500. To keep it, keep your security contacts current with us and fix any critical issue we report to you within 30 days, or on a timeline we agree in writing. A claim-free year is a policy year in which we paid nothing beyond your **retention**, apart from Coverage A, pre-

incident assistance, and the cost of investigating an **early warning** or suspected **incident** that turned out not to be an **incident**. A critical issue is a vulnerability on the Known Exploited Vulnerabilities catalog, or one our scan rates critical, that we describe to you in writing.

2. **Calling early never counts against you.** Use of Coverage A or pre-incident assistance, including an **early warning** investigation that finds nothing, is not treated as a **claim** for this benefit or when we price your renewal.

7. OUR SERVICE STANDARDS

1. **24/7 response.** Our hotline is answered around the clock, and we aim to have a member of our incident response team contact you within one hour of your report.
2. **Decisions.** We aim to give you a written coverage position, citing the policy wording we rely on, within 30 days after receiving the documents we ask for.
3. **Payment.** We will pay undisputed amounts within 15 days after we agree on them. If we pay later, we add interest at 8% a year, compounded annually, from the day payment was due. This interest is in addition to any remedy the law gives you.
4. **Cash advance for business interruption.** Once we confirm that Coverage D, E or P applies, we will advance 50% of our reasonable estimate of your loss to date, up to 25% of the policy aggregate limit or the limit of the coverage that applies, whichever is lower, within 10 business days, and update the advance as the loss develops.
5. **One accountant, one number.** You may choose a single forensic accountant from our panel to measure your business interruption loss for both of us.

8. RESOLVING DISAGREEMENTS

1. **Free internal review.** If you disagree with a coverage decision, you may ask for review by a claims professional who was not involved in it. We will respond within 30 days.
2. **Mediation.** If we still disagree, either of us may ask for non-binding mediation. We will pay the mediator's fees.
3. **Court or arbitration.** After that, either of us may go to court in the state shown in Item 11 of the Declarations. You may choose arbitration instead, binding where state law allows.

9. OTHER INSURANCE

1. Coverages A and B apply first, before any other insurance. Coverage H applies in excess of any crime or fidelity insurance you have. All other coverages apply in excess of other valid insurance, unless that insurance is written specifically to sit above this policy.
2. **Professional liability insurance.** If a **claim** arising from a **security failure** or **privacy event** could also be covered by your professional liability (errors and omissions) insurance, Coverage I responds as if that other insurance did not exist. We will not refuse or delay your defense because of it, and we will seek any contribution directly from the other insurer.

10. RECOVERIES AND SUBROGATION

1. After we pay, we take over your rights to recover the payment from others, including your bank, and you will help us pursue them. You may waive those rights in a written contract signed before the **incident**.
2. Money recovered, after the costs of recovering it, goes first to reimburse your **retention** and any uninsured loss, then to us.

11. GENERAL TERMS

1. **Territory.** This policy covers **incidents** anywhere in the world and **claims** brought anywhere in the world, where legally permitted.
2. **The named insured acts for everyone.** The **named insured** gives and receives notices, pays premium and receives refunds for all **insureds**.
3. **Assignment.** This policy cannot be assigned without our written consent.
4. **Bankruptcy.** Your bankruptcy or insolvency does not relieve us of our obligations.
5. **State law.** If any term conflicts with the law of the state where this policy is issued, it is amended to meet that law's minimum requirements.
6. **Headings and summaries.** Headings, the cover page and the "If you suspect an incident" summary are for convenience and do not change coverage.
7. **Liberalization.** If we broaden this policy form for new policies during your **policy period** without charging more, you automatically get the broader terms.
8. **Entire agreement.** The Declarations, **application**, this policy form and any endorsements make up the entire contract. All amounts are in U.S. dollars.

12. SECURITY SERVICES WE OFFER

We may offer you security tools and services, such as vulnerability alerts, phishing training or email security, free or at a reduced cost. They are not part of this policy's coverage, and we offer them on the same terms to every policyholder in the same risk class. Using them, choosing not to use them, or any failure of them is never a reason for us to deny or reduce payment under this policy, except under Section III, part 1.7 when we have sent the written notice it describes.